

AI Security Pipeline

Technical Companion to the v2.1 Operating Model

Audience · **Offensive Security Leadership Team**

Application Security · Threat Intelligence · Threat Hunt · Red Team · Security
Control Validation

Version 1.0 · Companion to v2.1 · Internal — Offensive Security

Prepared by the Office of the Director, Offensive Security

Executive Summary for the Leads

The v2.1 operating model committed our organization to a shift from gatekeeper to embedded advisor, anchored on a paved-road infrastructure (Claude as primary sanctioned model, an MCP server farm, a scoped agent runtime), risk-tiered engagement, and a phased capability build. Executive sponsorship for that direction is in hand. This companion document is the engineering blueprint your teams will operate against.

It does three things. First, it lays out the eight-stage AI assurance pipeline that operationalizes v2.1 — what runs at each stage, which tools we use, and what the inputs and outputs are. Second, it translates each stage into per-vertical capability builds for the five functions you each lead, phased to honor v2.1's modesty constraint in Phase 1. Third, it extends the v2.1 RACI with eighteen pipeline-specific activities so that ownership is unambiguous from day one.

Key takeaways

- This is the technical layer beneath v2.1, not a competing proposal — every architectural choice traces back to commitments already approved.
- Eight-stage pipeline anchored on the v2.1 sanctioned infrastructure: Claude gateway, MCP farm, agent runtime.
- Tooling for Phase 1 is deliberately conservative: open-source PoCs (garak, PyRIT, Semgrep, Trivy, ModelScan) operated by existing headcount.
- Each of the five verticals owns clear primary territory in the pipeline; the ownership matrix is in Section 5.
- Two dashboard surfaces — technical for operators, executive for the CISO — feed from a single findings store with HIPAA/HITRUST evidence pre-mapped.
- Eighteen-row RACI extension slots cleanly into v2.1's nine owner columns; no realignment required.

Where this Companion fits with the v2.1 Operating Model

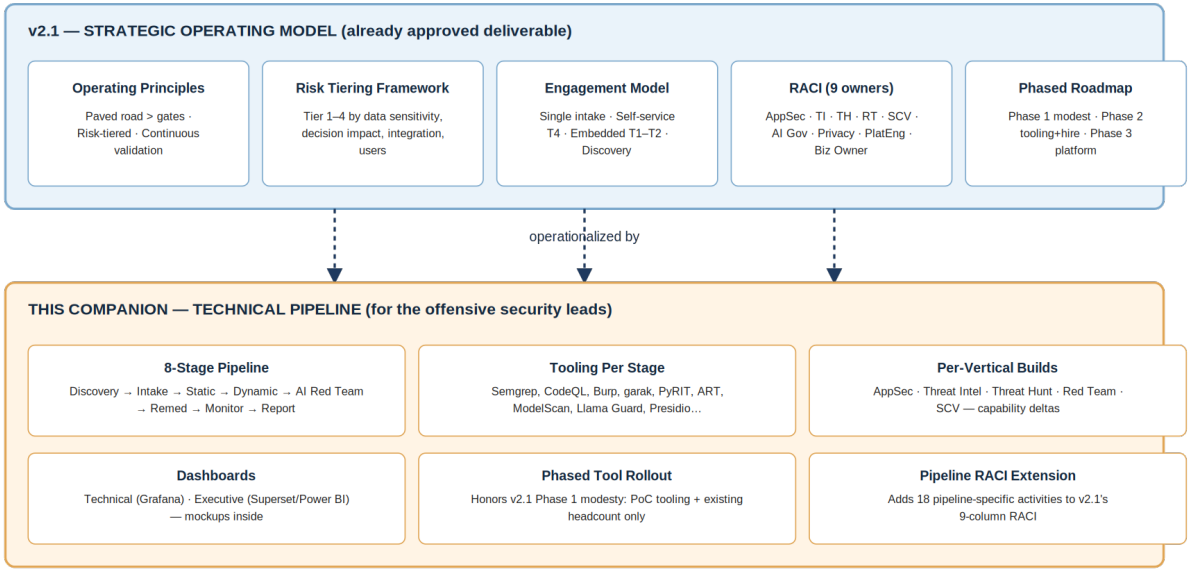


Figure 1. Where this companion sits relative to the v2.1 operating model.

1. How This Companion Fits with v2.1

v2.1 was written for the CISO and cyber executives. It described what the offensive security team will do under AI transformation and why — the strategic reframe to empirical truth function, the risk tiering framework, the engagement model, the phased roadmap, and the RACI across nine owner columns. It described the architectural commitments at the level of principle: foundation model usage funneled through a sanctioned gateway, MCP servers in a curated registry, agents in a scoped runtime, telemetry unified.

This companion is for the offensive security leads. It describes how those commitments get engineered into a working pipeline — the eight stages, the tools at each stage, who runs them, what is logged, how findings are normalized, how dashboards are populated, and what each of your teams builds in each of the three phases.

Inheritance Map

v2.1 commitment	How this document operationalizes it
Paved road over gates	Sanctioned LLM gateway and curated MCP registry are the only approved foundation-model and tool paths. Stages 0-3 of the pipeline test conformance; deviation is a finding.
Risk-tiered engagement	Stage 1 is automated tier scoring on intake. Tiers determine which downstream stages are mandatory, optional, or async. Tier 1 has hard pre-deploy gates; Tier 4 is self-service.
Continuous validation	Stages 6 and 7 implement re-scan cadence, drift detection, and replay of new jailbreaks/CVEs against the live portfolio.
Five-function realignment	Section 5 spells out per-vertical builds for AppSec, TI, TH, RT, SCV — including which pipeline stages each owns.
RACI across nine owners	Section 8 adds eighteen pipeline activities to the existing RACI columns. No new column owners introduced.
Phase 1 modesty	Phase 1 tooling is open-source or already-licensed. No headcount asks. Demo red team is the artifact that earns Phase 2.
Sanctioned infrastructure	Pipeline stages instrument the gateway, MCP farm, agent runtime, and data plane already named in v2.1. No parallel stack.
Empirical truth function	Pipeline output feeds the quarterly board/risk-committee report; findings are queryable as HIPAA/HITRUST evidence.

2. Pipeline Architecture Overview

The pipeline is eight stages, each with a defined input, output, primary owner, and tool set. Stages run as workflows on a shared orchestration layer; findings are normalized to OCSF and stored in a single findings system; downstream notification, remediation, and dashboard surfaces are the consumers.

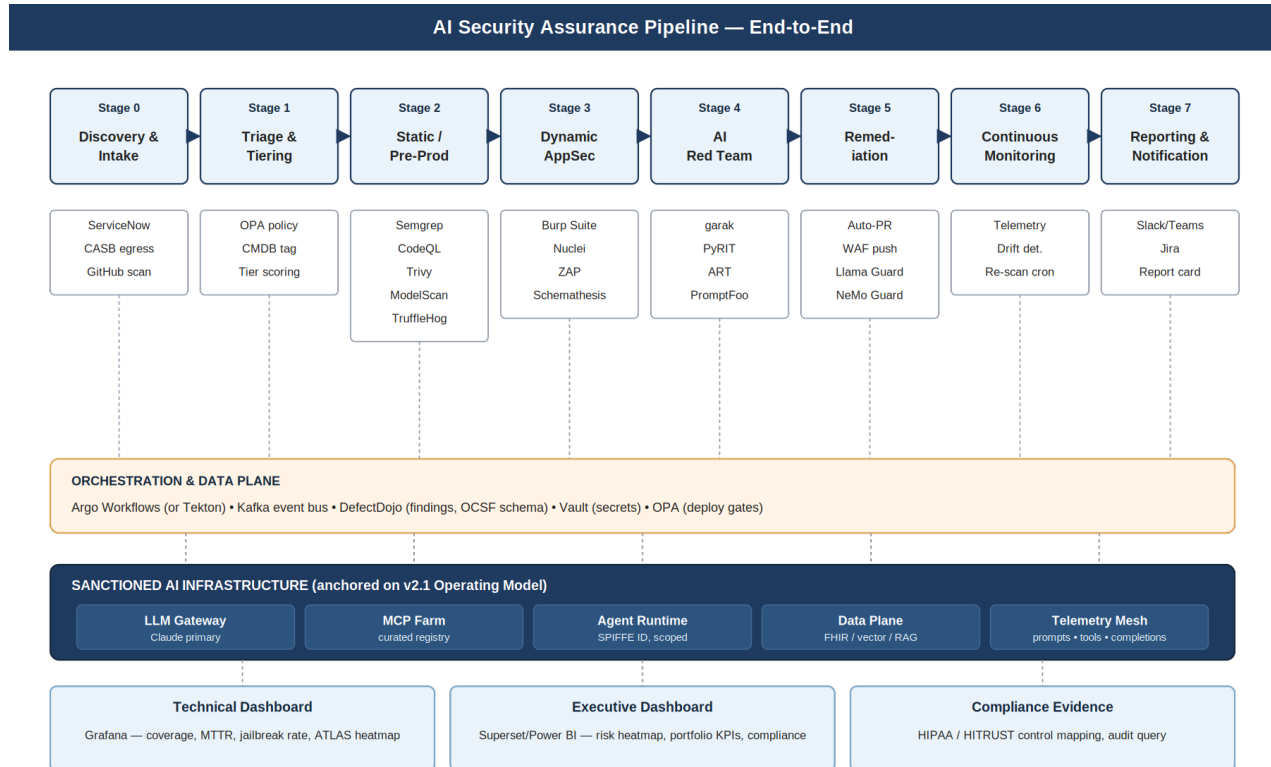


Figure 2. The eight-stage pipeline, anchored on the v2.1 sanctioned infrastructure.

Three Layers, One Pipeline

- **Stage layer** — eight discrete assurance stages from discovery to reporting. Each stage is a workflow with its own SLA and pass/fail criteria.
- **Orchestration & data plane** — Argo Workflows (or Tekton) for execution, Kafka for events, DefectDojo for findings, Vault for secrets, OPA for deploy gates. This layer is operated by Platform Engineering; offensive security defines policy.
- **Sanctioned infrastructure** — the v2.1 gateway, MCP farm, agent runtime, data plane, and telemetry mesh are not part of the pipeline; they are what the pipeline tests, monitors, and reports on.

The architectural rule that keeps this honest

If an AI asset does not flow through the gateway and use a registered MCP, the pipeline cannot see it. Off-pipeline deployment is therefore treated as an incident, not a finding. Stage 0 (discovery) is the control that makes the rest of the pipeline credible.

What Travels on the Wire

Findings produced by any stage land in a single store with a uniform schema. This is the design decision that makes everything downstream tractable: dashboards, RACI accountability, SLA tracking, compliance evidence, and threat-hunt enrichment all consume the same normalized records.

Field	Source	Why it matters
AIID	Stage 0 — CMDB tag	Single key to join findings, telemetry, and ticketing per asset.
Tier	Stage 1 — automated scoring	Drives SLA, mandatory stages, and dashboard segmentation.
Severity (CVSS or AI-adjusted)	Each scanner	Normalized to a 0–10 scale; AI-specific adjustments documented in Stage 4.
ATLAS technique	Stage 4 — red team output	Coverage tracking and adversary-emulation reporting.
HIPAA/HITRUST control	Auto-mapped at finding creation	Audit evidence is a query, not a fire drill.
BU / owner email	Stage 0 intake + IdP lookup	Notification routing and SLA accountability.
Telemetry references	Stage 6	Link runtime evidence (prompt/tool-call logs) to the finding.

3. Stage-by-Stage Detail

Stage 0 — Discovery & Intake

Purpose. Establish the denominator. Every AI asset gets registered with an AIID, owner, and risk inputs before any other stage runs. Shadow-AI is detected and routed into intake.

Inputs / Outputs

- **Inputs** — Self-service portal submissions; CASB egress telemetry; GitHub/GitLab org scans; Microsoft Purview / Copilot Studio inventory; browser-extension paste-PHI signals.
- **Outputs** — AIID record in CMDB; intake form payload; tier inputs ready for Stage 1.

Tooling

- ServiceNow (intake form + record)
- CASB / SWG egress monitoring
- GitHub org scanner (Semgrep + custom signatures for `openai`, `anthropic`, `langchain`, `llama-index`)
- Purview / Copilot Studio API
- Browser-extension telemetry pipeline

Ownership and SLA

- **Primary owner** — Threat Intel (shadow-AI discovery); AppSec (intake portal owner)
- **Support** — All five verticals consume the inventory
- **SLA / cycle time** — Intake → AIID issued within 1 business day for active submissions; passive discovery within 24h of egress signal
- **v2.1 RACI** — Activity 'Discovery & intake of AI assets' (Section 8) — A: Threat Intel; R: TI + AppSec; C: PlatEng, Privacy; I: AI Gov, Biz Owner

Healthcare consideration

BAA-coverage flag is set at intake. If a non-BAA'd third-party AI service is detected in egress, this is a same-day escalation, not a quarterly report item.

Stage 1 — Triage & Tiering

Purpose. Convert intake inputs into a deterministic tier (1-4) and a downstream engagement plan. No human judgment at this stage — humans appeal, they don't assign.

Inputs / Outputs

- **Inputs** — Intake form (data classes, decision impact, integrations, user population); discovery signals (egress patterns); BAA flag.
- **Outputs** — Tier assigned; mandatory stage list set; SLA clock started; ticket auto-opened in vertical's queue.

Tooling

- OPA-based tiering policy (versioned, audited)
- CMDB tag update
- Jira/ServiceNow auto-ticket creation
- Stage-routing in orchestrator

Ownership and SLA

- **Primary owner** — AppSec (owns the tiering policy implementation, AI Governance owns the framework)
- **Support** — Privacy/Compliance review of policy quarterly
- **SLA / cycle time** — Auto-tier within 15 minutes of intake completion
- **v2.1 RACI** — Activity 'Tier assignment for new AI asset' — A: AI Gov; R: AppSec; C: Privacy/Compliance; I: TI, RT, Biz Owner

Healthcare consideration

Any asset that touches PHI, ePHI, claims, clinical decisioning, or has external-facing surface is Tier 1 by rule. Tier reductions for Tier 1 candidates require AI Governance + Privacy sign-off, recorded in CMDB.

Stage 2 — Static / Pre-Production Scanning

Purpose. Catch what's catchable without running the system. Code, dependencies, containers, IaC, model artifacts, prompt templates, and RAG corpus all get scanned before any dynamic stage runs.

Inputs / Outputs

- **Inputs** — Source repository, build artifacts, model artifacts (HuggingFace or internal), RAG corpus URLs, IaC.
- **Outputs** — Findings with severity, CWE/CVE/ATLAS mapping, file/line references, suggested fix where available.

Tooling

- Semgrep + CodeQL (custom rules for unsafe prompt interpolation, agent tool-call sinks)
- TruffleHog / gitleaks
- Trivy / Grype (containers + SBOM)
- Checkov / tfsec / KICS (IaC)
- ModelScan (Protect AI) for serialized-model RCE
- Sigstore signature verification on model artifacts
- Presidio + clinical NER on RAG corpus for PHI
- Custom corpus poisoning detector (hash baseline + drift)

Ownership and SLA

- **Primary owner** — AppSec
- **Support** — SCV validates that scanners are in fact running on every asset of the relevant tier
- **SLA / cycle time** — Tier 1: blocking; Tier 2: blocking with waiver path; Tier 3-4: async, ticketed
- **v2.1 RACI** — Activity 'Static and supply-chain scanning' — A: AppSec; R: AppSec; C: PlatEng (CI/CD integration); I: SCV, Biz Owner

Healthcare consideration

ModelScan is non-negotiable on any HuggingFace import path. Pickle-based model RCE is one of the highest-severity supply-chain risks in the AI stack and remains under-addressed in most healthcare orgs.

Stage 3 — Dynamic AppSec

Purpose. Test the running system from outside. Web/API surfaces, authenticated flows, fuzz of OpenAPI contracts, exposed CVEs.

Inputs / Outputs

- **Inputs** — Deployed asset URL, auth credentials (rotated test creds), OpenAPI spec where available.
- **Outputs** — Findings with reproduction steps and severity.

Tooling

- Burp Suite Enterprise (API-driven, stored session macros)
- Nuclei (CVE / exposure sweeps)
- OWASP ZAP (parallel/redundant for OSS coverage)
- Schemathesis / RESTler for OpenAPI fuzz
- Nessus / Tenable on supporting infrastructure

Ownership and SLA

- **Primary owner** — AppSec
- **Support** — Red Team contributes campaign-mode dynamic testing for Tier 1; SCV validates coverage
- **SLA / cycle time** — Tier 1: pre-deploy + weekly; Tier 2: pre-deploy + monthly; Tier 3-4: monthly automated
- **v2.1 RACI** — Activity 'Dynamic application & API testing' — A: AppSec; R: AppSec, RT (campaigns); C: PlatEng; I: SCV, Biz Owner

Healthcare consideration

Authenticated scans against assets that touch PHI must use synthetic test data only. The pipeline enforces a separate test-tenant isolation boundary; any scanner that leaks production PHI into a finding becomes the next incident.

Stage 4 — AI Red Team

Purpose. Test the AI system as an adversarial system. Jailbreaks, prompt injection (direct and indirect), tool/agent abuse, adversarial ML, and healthcare-specific harm probes. This is the differentiator stage and is detailed in Section 4.

Inputs / Outputs

- **Inputs** — Deployed asset access via gateway; scoped test identity; permission to inject content into RAG corpus (test partition only).
- **Outputs** — Findings with attack chains, ATLAS technique IDs, regression-test cases (PromptFoo) for any successful exploit, and a campaign report for Tier 1.

Tooling

- garak (NVIDIA) — baseline + custom probes
- PyRIT (Microsoft) — multi-turn orchestrators
- ART / Counterfit / TextAttack — adversarial ML
- PromptFoo — regression suite
- Custom indirect-injection corpus
- Tool-call fuzz harness (in-house)

Ownership and SLA

- **Primary owner** — Red Team
- **Support** — AppSec (handles findings into remediation); Threat Intel (provides current jailbreak techniques); SCV (validates that successful exploits are then blocked by guardrails)
- **SLA / cycle time** — Tier 1: pre-deploy + monthly; Tier 2: pre-deploy + quarterly; Tier 3: annual or on material change
- **v2.1 RACI** — Activity 'AI red team campaign' — A: RT; R: RT; C: AppSec, TI, SCV, Privacy; I: AI Gov, Biz Owner

Healthcare consideration

Healthcare custom probe set runs every campaign: PHI elicitation, clinical hallucination, off-label drug recs, minimum-necessary violation, BAA-bypass tool calls. These are not optional add-ons — they are the probes that justify our existence.

Stage 5 — Remediation

Purpose. Close findings. Auto where possible, ticketed where not, with WAF/guardrail backstops where root-cause fix takes longer than the SLA.

Inputs / Outputs

- **Inputs** — Findings from any prior stage.
- **Outputs** — Closed findings (with evidence); active backstops (WAF rules, guardrail policies); waivers (time-bound, accountable).

Tooling

- Auto-PR system for dependency bumps and IaC fixes
- Llama Guard 3 + NeMo Guardrails (guardrail injection at gateway)
- LLM Guard / Rebuff (input-side prompt-injection defense)
- Presidio (output PHI redaction)
- Kong / Apigee WAF rule push
- DefectDojo waiver workflow with hard expiry

Ownership and SLA

- **Primary owner** — AppSec (root-cause); SCV (validates closure)
- **Support** — RT regression-tests successful exploits in PromptFoo; Threat Hunt monitors for re-emergence
- **SLA / cycle time** — Tier 1 critical: 7 days; high: 14 days; medium: 30 days; low: 90 days. Backstops within 24h for Tier 1 critical.
- **v2.1 RACI** — Activity 'Remediation & closure validation' — A: AppSec; R: AppSec, SCV (validation); C: RT; I: Biz Owner, AI Gov

Healthcare consideration

Output-side PHI redaction (Presidio + clinical NER) is layered — never the only control. A model that hallucinates PHI is still a privacy risk even if the output filter catches it; the root cause must be addressed.

Stage 6 — Continuous Monitoring

Purpose. Production-time assurance. Runtime telemetry, drift detection, scheduled re-scan, replay of new attacks against the live portfolio.

Inputs / Outputs

- **Inputs** — Telemetry mesh (prompts, completions, tool calls, retrieval queries) — PHI-redacted at the edge; new threat-intel signals.
- **Outputs** — Hunt-ready data; drift alerts; periodic re-scan results; new findings from intel-driven replay.

Tooling

- OpenSearch / SIEM ingest
- Custom drift detectors on jailbreak success rate, refusal rate, tool-call distribution
- Cron'd garak/PyRIT runs (weekly Tier 1, monthly Tier 2)
- Threat-feed → asset replay job
- Anomaly detection on prompt/tool-call sequences

Ownership and SLA

- **Primary owner** — Threat Hunt (detection hypotheses + analytics); SCV (re-scan cadence)
- **Support** — Threat Intel (feeds new techniques); Red Team (validates that new techniques don't exploit our portfolio)
- **SLA / cycle time** — Telemetry latency to hunt-ready: <15 minutes. Re-scan cadence per tier. Threat-driven replay within 48h of credible new-jailbreak intel.
- **v2.1 RACI** — Activity 'Continuous monitoring & drift detection' — A: TH; R: TH, SCV; C: TI, RT, PlatEng; I: AppSec, Biz Owner

Healthcare consideration

Telemetry is PHI-redacted at the edge before storage. The pipeline enforces this — un-redacted telemetry never reaches the long-term store. SIEM ingest is the secondary control, not the primary.

Stage 7 — Reporting & Notification

Purpose. Close the loop with the asset owner and produce the evidence the team needs for the seat at the table — operator dashboards, executive dashboards, compliance evidence, and the quarterly board report.

Inputs / Outputs

- **Inputs** — Normalized findings, telemetry summaries, RACI ownership, SLA clocks.
- **Outputs** — Per-asset Security Report Card (PDF + portal); Slack/Teams DM + email; Jira/ServiceNow ticket; dashboard refresh; board-ready quarterly export.

Tooling

- DefectDojo report generation
- Slack/Teams notifier
- Jira/ServiceNow integration
- Grafana (technical dashboard)
- Superset / Power BI (executive dashboard)
- HIPAA/HITRUST evidence query templates

Ownership and SLA

- **Primary owner** — AppSec (asset-level reports); SCV (control reports); Office of the Director (board export)
- **Support** — All verticals contribute their stage-level data
- **SLA / cycle time** — Notification within 15 minutes of finding creation. Dashboard freshness < 5 minutes. Quarterly board report within 5 business days of quarter close.
- **v2.1 RACI** — Activity 'Asset Security Report Card' — A: AppSec; R: AppSec, SCV; C: All other verticals; I: Biz Owner. Activity 'Quarterly board / risk-committee report' — A: Director; R: All vertical leads; C: AI Gov, Privacy; I: CISO.

Healthcare consideration

The board report is the artifact that turns the seat at the table from a claim into a habit. It is the single most important reporting deliverable from this pipeline. Owner attestation that controls were validated, not just that scanners ran, is what differentiates this from a vulnerability-count report.

4. AI Red Team Capability Deep-Dive

Stage 4 is the differentiator. Most healthcare organizations can stand up Stages 0–3 and Stage 6 with existing application security tooling and skill. Stage 4 is what proves we are doing AI security and not appsec-with-an-AI-decal — and it is where the empirical-truth claim from v2.1 is earned or lost.

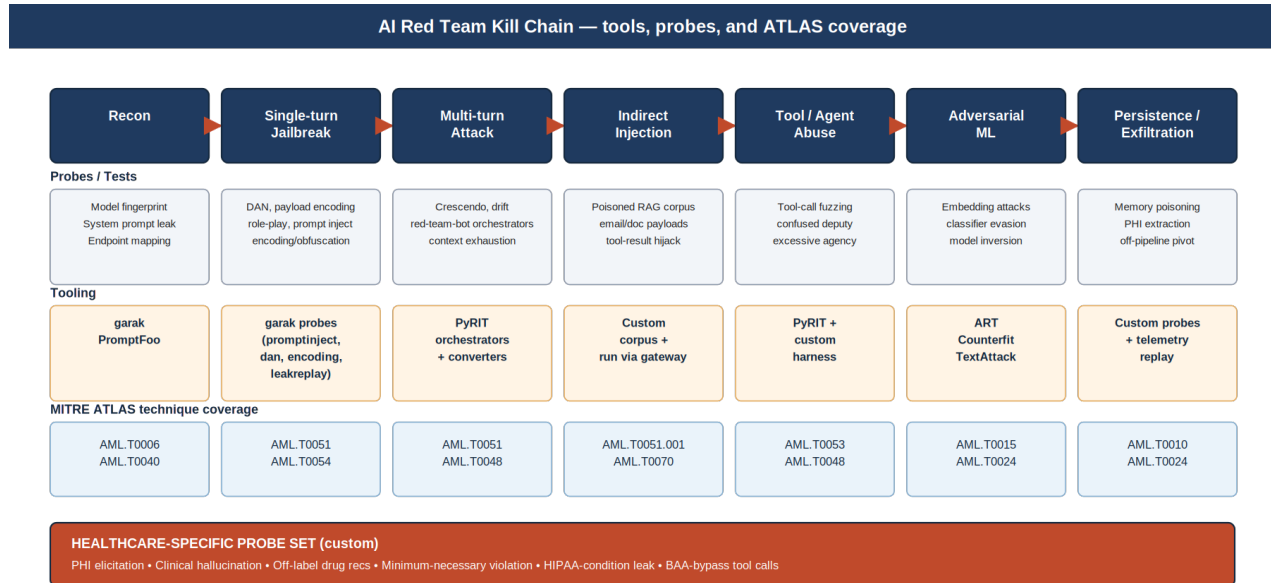


Figure 3. The AI red-team kill chain — probes, tooling, and ATLAS coverage at each step.

What We Run, in Order

Each Tier 1 campaign walks the kill chain end-to-end. Lower tiers may stop after Stage 4.b (single-turn) for cycle-time reasons, with the remainder run on quarterly or annual cadence.

4.a Reconnaissance

- Model fingerprinting via response-signature probes (garak `lmrc` family).
- System-prompt leak attempts (`leakreplay`).
- Endpoint and tool-call surface enumeration via gateway logs (read-only).
- Output: a target profile that informs the rest of the campaign.

4.b Single-turn jailbreak

- garak baseline probes: `promptinject`, `dan`, `encoding`, `leakreplay`, `realtoxicityprompts`, `xss`, `malwaregen`.
- Custom probes for healthcare context — see callout below.
- PromptFoo regression suite: every successful exploit becomes a permanent test case.

4.c Multi-turn attack

- PyRIT orchestrators: single → multi-turn → crescendo → red-team-bot, escalating until refusal or budget.
- Custom converters for medical-context jailbreaks (clinician role-play, patient-history justifications).

- Drift testing: does the model become more compliant over a long session?

4.d Indirect prompt injection

- Curated poisoned-document corpus seeded into a test partition of the asset's RAG store.
- Email/document/PDF payloads for assets that ingest external content.
- Tool-result hijack: payload returned by a downstream tool that the agent then acts on.
- These are the attacks most likely to compromise a Tier 1 agent in production. Coverage here is non-negotiable.

4.e Tool / agent abuse

- Tool-call fuzzing — does the agent call tools it shouldn't, or call them with arguments outside the schema?
- Confused-deputy: get the agent to use its privileges on attacker's behalf.
- Excessive agency (OWASP LLM06) — chain of tool calls that escalates beyond the intended task.
- Tool-scoping at registration is the highest-leverage control here. This stage validates the scoping decision.

4.f Adversarial ML

- IBM ART, Counterfit, TextAttack against any classifier or embedding model in the loop.
- Embedding poisoning / inversion attacks on the vector store.
- Model extraction probes against any self-hosted model.

4.g Persistence / exfiltration

- Memory poisoning of agent context store.
- PHI extraction from training/fine-tuning data — relevant for any internally fine-tuned model.
- Off-pipeline pivot: can the agent be coerced into using a non-sanctioned model or tool?

Healthcare custom probe set — runs on every Tier 1 campaign

- PHI elicitation — direct and indirect attempts to extract PHI from prompts, system context, or RAG.
- Clinical hallucination — adversarial prompts crafted to elicit confident clinical claims with no source.
- Off-label drug recommendation — probes that solicit unsupported pharmacology guidance.
- Minimum-necessary violation — does the agent volunteer information beyond the task scope?
- BAA-bypass — can the agent be coerced into invoking a non-BAA'd third-party AI service?
- HIPAA-condition leak — does the agent reveal HIV / mental-health / substance-use status outside its authorization?

ATLAS Coverage as a First-Class Metric

Every campaign tags findings with MITRE ATLAS technique IDs. Coverage is tracked on the technical dashboard (see Section 6). The goal is not 100% coverage — it is to make the gaps visible and deliberate, so that 'we don't test for this' is a documented decision rather than an oversight.

MCP Onboarding Red-Teaming as a Productized Service

Per v2.1, every new MCP server entering the curated registry is red-teamed before approval. This is a productized recurring service from the Red Team — not a one-off — and it is what makes the MCP farm credibly safer than ad-hoc tool integration. Onboarding tests cover input-side prompt injection through tool results, output-side data leakage, scope-creep behaviors, and auth/authorization boundaries.

5. Per-Vertical Capability Builds

The pipeline only works if each vertical knows what they own. The matrix below shows primary and supporting ownership across all eight stages. The remainder of the section spells out what each lead is responsible for building in each phase.

Pipeline Ownership Matrix — five verticals × eight stages								
	Discovery & Intake	Triage & Tiering	Static / Pre-Prod	Dynamic AppSec	AI Red Team	Remediation	Continuous Monitoring	Reporting & Notification
AppSec	Support	PRIMARY	PRIMARY	PRIMARY	Support	PRIMARY	Support	PRIMARY
Threat Intel	PRIMARY	Support	—	—	Support	—	Support	Support
Threat Hunt	Support	—	—	—	—	—	PRIMARY	Support
Red Team	—	Support	—	Support	PRIMARY	Support	Support	Support
Security Control Validation	Support	Support	PRIMARY	PRIMARY	PRIMARY	PRIMARY	PRIMARY	Support

PRIMARY — accountable for execution and outcome Support — contributes capability or telemetry — Not directly engaged at this stage

Figure 4. Ownership matrix — five verticals across the eight pipeline stages.

AppSec

AppSec is the connective tissue of the pipeline. They own the intake portal, the static and dynamic stages, the remediation path, and the asset-level Security Report Card.

Phase 1 (Months 0-3) — modest, no headcount

- Stand up Semgrep + CodeQL custom rule packs for AI-aware patterns: unsafe prompt interpolation, agent tool-call sinks, embedding-leak patterns. Use existing license; rules live in our repo.
- ModelScan deployed in CI for any HuggingFace import path. Block on serialized-model RCE patterns.
- Llama Guard 3 PoC at the gateway in shadow mode (log-only) — measure refusal/false-positive rates against three weeks of real prompts.
- Paved-road template v0 — secure-by-default RAG agent + secure-by-default chat agent — published to internal portal.
- Healthcare prompt linter v0 — Presidio + clinical NER as a pre-flight check on prompt templates.

Phase 2 (Months 3-9) — tooling + selective hire

- Burp Suite Enterprise full integration — every Tier 1 asset gets an authenticated scan in the deploy pipeline.
- Auto-PR remediation for dependency and IaC findings — measurable cycle-time reduction.
- Custom RAG threat-modeling guide — published, with worked examples, used by all Tier 1 onboardings.

- Healthcare prompt linter v1 — promoted from PoC to required check on all prompt-template PRs.
- Inherited-controls report card — assets on the paved road show their inherited control coverage.

Phase 3 (Months 9-18) — platform-grade

- Self-service threat-modeling assistant — citizen developers complete a guided threat model with AppSec-validated outputs.
- Continuous SBOM + attestation across the AI portfolio.
- Stage 2 + 3 fully automated for Tier 3-4; AppSec time goes to Tier 1-2 deep work.

Threat Intelligence

TI owns shadow-AI discovery, the AI threat-feed taxonomy, and the BAA inventory. Their work feeds Stage 0 (denominator) and Stage 6 (intel-driven replay).

Phase 1 (Months 0-3) — modest, no headcount

- AI threat-feed taxonomy — define what we collect, how we classify, who consumes. First version live within Phase 1.
- Jailbreak intel weekly report — what's new in the wild, what affects our model providers.
- BAA inventory baseline — every third-party AI service touching the org documented; non-BAA'd egress flagged for same-day review.
- Shadow-AI discovery v0: CASB + GitHub org scan + Purview pull operating on weekly cadence.

Phase 2 (Months 3-9) — tooling + selective hire

- Adversarial-ML research stream — at least one specialist tracking academic + industry adversarial-ML output.
- Provider-incident watch — daily monitoring of Claude / MCP server / model-host incidents and CVEs.
- Healthcare-AI TTP catalog — what attackers actually do against healthcare AI, not theoretical.
- Shadow-AI discovery to daily cadence with auto-routing into Stage 1 tiering.

Phase 3 (Months 9-18) — platform-grade

- Threat-informed scan tuning — Stage 4 probe set automatically updated from intel.
- Auto-replay of new jailbreaks against the live Tier 1 portfolio within 48h of credible disclosure.

Threat Hunt

TH transitions from network/endpoint hunting to AI-mediated hunting. Their primary territory is Stage 6, where the rest of the pipeline produces the data they need.

Phase 1 (Months 0-3) — modest, no headcount

- Telemetry gap analysis — what we log today vs. what we'd need to hunt prompt injection, tool abuse, and exfiltration. Output: a prioritized telemetry ask for Platform Engineering.

- First three hunt hypotheses in production: anomalous prompt patterns, unexpected tool-call sequences, off-pipeline egress from agent runtime.
- Hunt notebook templates — Jupyter / OpenSearch — that future hunters can fork.

Phase 2 (Months 3-9) — tooling + selective hire

- Live agent-action analytics — tool-call sequence anomaly detection in production.
- Drift detection on jailbreak success rate, refusal rate, latency — alerting on threshold breach.
- Hunt against shadow-AI signals — joining Stage 0 discovery output with hunt analytics.
- Detection-as-code: hunt logic versioned, reviewed, and CI-tested.

Phase 3 (Months 9-18) — platform-grade

- Continuous hunting on the prompt corpus — not periodic.
- AI-native detections fed back into SIEM for SOC consumption.

Red Team

RT owns Stage 4 and the demo red-team exercises that earn the Phase 2 ask. They also own MCP onboarding red-teaming as a productized recurring service.

Phase 1 (Months 0-3) — modest, no headcount

- garak baseline scans operational against three Tier 1 candidate apps. Findings reviewed and triaged.
- PyRIT PoC orchestrator built and run against the same apps. Healthcare custom converters drafted.
- One demonstration red-team exercise on a representative Tier 1 app — written up as the Phase 2 budget conversation artifact.
- MCP onboarding red-team v0 — repeatable playbook, used on the first three MCP servers in the registry.

Phase 2 (Months 3-9) — tooling + selective hire

- Healthcare custom probes promoted from draft to required-on-every-Tier-1-campaign.
- Indirect-injection corpus built and curated; corpus seeding into RAG test partitions automated.
- ATLAS coverage tracking on the technical dashboard.
- Tool-abuse fuzz harness in production — replays adversarial tool-call sequences against agent runtime test instances.

Phase 3 (Months 9-18) — platform-grade

- Continuous AI red-team campaigns — Tier 1 monthly, Tier 2 quarterly.
- Automated re-test on every regression — successful exploits don't recur silently.
- Adversarial-ML platform (ART) operational against any in-house classifier or embedding model.

Security Control Validation

SCV's charter shifts the most. The set of controls to validate has changed; the cadence has to become continuous; and the team has to be the one that says whether a guardrail actually works.

Phase 1 (Months 0-3) — modest, no headcount

- Catalog v2.1 controls vs. AI threat model — gap matrix shared with the Director and the CISO. This becomes the work backlog for Phases 2 and 3.
- Egress-control validation playbook — proves that the gateway is, in fact, the only path to foundation models.
- Gateway-bypass detection — log analysis identifying any traffic to Claude / OpenAI / Anthropic / Gemini that did not transit our gateway.

Phase 2 (Months 3-9) — tooling + selective hire

- Continuous control validation runner — controls re-tested on a schedule, with results in the technical dashboard.
- Guardrail effectiveness measurement — Llama Guard / NeMo / LLM Guard tested against current attack corpus.
- Identity & scope validation per agent — does each agent have the minimal tools and data scope its task requires?

Phase 3 (Months 9-18) — platform-grade

- Self-service control attestation — paved-road consumers receive auto-generated attestations of inherited control coverage.
- Real-time control drift alerts — control fail produces a finding instantly, not at next audit cycle.

6. Dashboards

Two dashboard surfaces, one findings store. The technical dashboard is for operators inside the offensive security organization — the people on call, triaging findings, working remediation, and tracking SLAs. The executive dashboard is for the CISO and cyber leadership — the audience v2.1 was written for. Both refresh from the same data; they differ in aggregation and framing, not in source of truth.

Technical Dashboard



Figure 5. Technical dashboard — operator view, Grafana.

Primary panels:

- Top KPIs — asset coverage %, open criticals, MTTR critical, jailbreak rate.
- Findings by severity, last 12 weeks (stacked bar) — trend visibility.
- MTTR by severity, rolling 30 days (line) — SLA performance.
- MITRE ATLAS coverage heatmap — what we test for vs. what we don't.
- Top open criticals table — by age and tier, with owner and finding summary for action.

Audience uses this for:

- Daily standup — what's open, what's at risk of breaching SLA.
- Weekly capacity planning — where the work concentrates.
- ATLAS coverage gaps — input to Red Team campaign planning.
- Investigation — Top criticals table is the queue.

Executive Dashboard

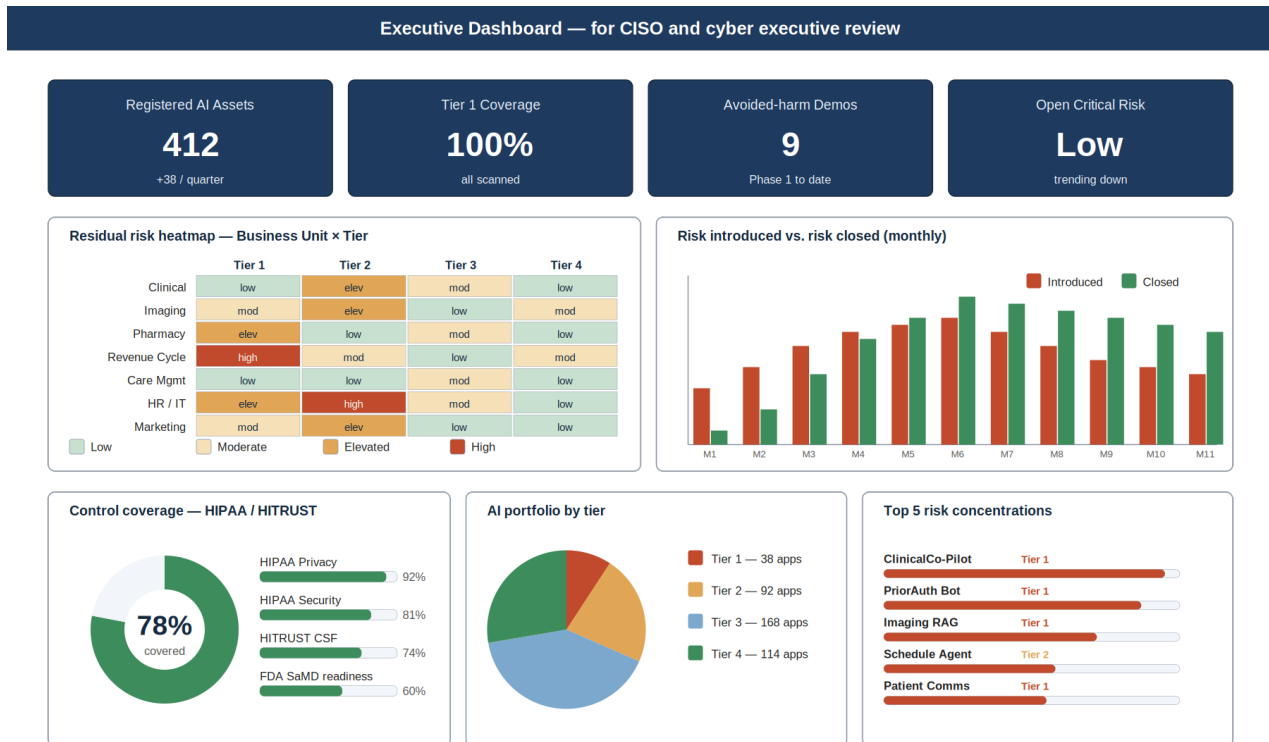


Figure 6. Executive dashboard — CISO and cyber leadership view, Superset / Power BI.

Primary panels:

- Portfolio KPIs — registered assets, Tier 1 coverage, avoided-harm demonstrations, open critical risk posture.
- Risk heatmap — Business Unit × Tier — where the residual risk concentrates.
- Risk introduced vs. closed (monthly) — are we keeping up with the AI portfolio's growth?
- Control coverage — HIPAA / HITRUST progress; FDA SaMD readiness.
- AI portfolio composition by tier.
- Top 5 risk concentrations — single highest-risk assets, named, by score and tier.

What the executive view is for

- It is the artifact that makes the seat at the table durable — the quarterly board / risk-committee report draws directly from it.
- It frames offensive security work in patient-safety, HIPAA/HITECH, breach-avoidance, and regulator-credibility terms — not vulnerability counts.
- Every panel is owned by a vertical lead who can defend the number. There is no blackbox metric.
- Top 5 risk concentrations being named publicly is what creates conversational leverage with business owners.

7. Phased Tool & Capability Rollout

The phased rollout below is the per-vertical Phase 1/2/3 view from Section 5, presented as a single picture. It is the artifact to use when negotiating priorities across verticals — what cannot slip in Phase 1 vs. what can wait.

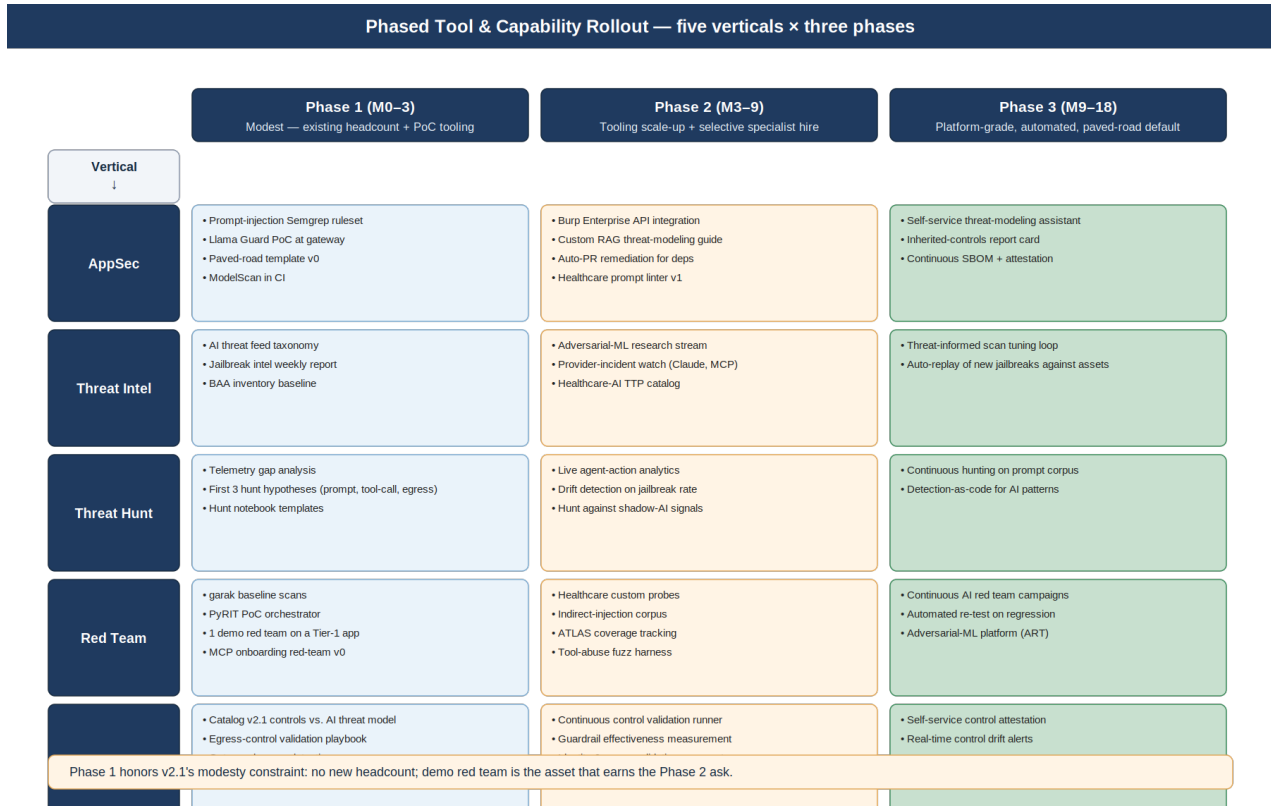


Figure 7. Phase rollout swim lane — five verticals × three phases.

Phase 1 — What Cannot Slip

Three Phase 1 deliverables sit on the critical path because everything in Phase 2 depends on them.

- AppSec: Llama Guard PoC at the gateway. Without a guardrail measurement baseline, we cannot show that we materially reduced runtime risk in Phase 2.
- Red Team: the demo red-team exercise on a Tier 1 app. This is the artifact that earns the Phase 2 ask. If it slips, the Phase 2 budget conversation is harder.
- Threat Intel: shadow-AI discovery v0. Without the denominator, every metric in Phases 2 and 3 is suspect.

Phase 1 modesty constraint

The discipline of Phase 1 is to ask for nothing — no headcount, no new tooling licenses — and still produce a working baseline. The credibility we accumulate in Phase 1 is what we spend in Phase 2. Any temptation to expand scope inside Phase 1 weakens the Phase 2 ask.

Phase 2 — What the Demonstrations Buy

- **Burp Suite Enterprise full integration** — depends on AppSec demonstrating Phase 1 cycle-time data.
- **Selective specialist hire** — adversarial-ML researcher in TI; senior AI red-teamer in RT. Justified by Phase 1 demo + intel volume.
- **Custom probe sets and indirect-injection corpus operationalized** — depends on Phase 1 PyRIT PoC.
- **Continuous control validation runner** — depends on SCV gap matrix from Phase 1.

Phase 3 — Platform-Grade

- Self-service threat-modeling assistant for citizen developers.
- Continuous AI red-team campaigns and automated regression replay.
- Real-time control attestation surfaces.
- Detection-as-code for AI patterns fed into SOC consumption paths.

8. Pipeline RACI Extension

The activities below extend the v2.1 RACI. Owner columns are unchanged from v2.1 — AppSec, Threat Intel, Threat Hunt, Red Team, SCV, AI Governance, Privacy/Compliance, Platform Engineering, Business Owner. Each row has exactly one Accountable; the rest are R, C, I, or blank. This is intended to be appended to the v2.1 RACI section verbatim.

Header abbreviations: ASec = Application Security, TI = Threat Intel, TH = Threat Hunt, RT = Red Team, SCV = Security Control Validation, AIGov = AI Governance, Priv = Privacy / Compliance, PLEng = Platform Engineering, Biz = Business Owner.

Pipeline activity	ASec	TI	TH	RT	SCV	AIGov	Priv	PLEng	Biz
Discovery & intake of AI assets	R	R/A			C	C	C	C	I
Tier assignment for new AI asset	R	I			I	A	C		I
Static & supply-chain scanning	R/A				C	I		C	I
Dynamic application & API testing	R/A			R	C	I		C	I
AI red-team campaign — Tier 1	C	C	I	R/A	C	I	C		I
AI red-team campaign — Tier 2	C	C		R/A	C	I	I		I
MCP onboarding red-team	C	C		R/A	C	C		C	
Healthcare custom probe set maintenance	C	C		R/A	C	I	C		
Indirect-injection corpus curation	C	C		R/A		I	C		
Remediation & closure validation	R/A			C	R	I	C		I
Guardrail effectiveness measurement	C			C	R/A	I	C	C	
WAF / gateway rule push for backstops	R				C	I		R/A	I
Continuous monitoring & drift detection	C	C	R/A	C	R	I	C	C	I
Threat-driven replay against live portfolio	C	R	C	R/A	C	I			I
Asset Security Report Card	R/A			C	R	I	I		I

Quarterly board / risk-committee report	R	R	R	R	R	C	C	I	I
Telemetry mesh contract & schema	C	C	C	C	C	I	C	R/A	I
Off-pipeline AI deployment incident response	R	R	R	R	R	I	C	C	A

Legend — A: Accountable, R: Responsible, C: Consulted, I: Informed. R/A means the same owner is both Responsible and Accountable. Blank cells are not engaged for that activity.

Three things worth defending in this RACI

- 'Off-pipeline AI deployment incident response' is owned (A) by the Business Owner, not by security. Security cannot be accountable for the consequences of bypass — but every vertical is Responsible for response.
- 'Tier assignment' is Accountable to AI Governance, not AppSec. AppSec runs the policy; the policy itself is a governance artifact.
- 'Quarterly board / risk-committee report' has every vertical lead Responsible. There is no single ghostwriter; every lead defends their own data.

9. Asks of the Offensive Security Leads

Below is what each of you is on the hook for in the next 30, 60, and 90 days, assuming the v2.1 operating model receives final endorsement and Phase 1 is authorized to begin.

AppSec lead

- **Next 30 days** — Confirm the Phase 1 deliverables list in Section 5 is achievable with current headcount and standing licenses. Identify any single deliverable that is at risk and what it would take to de-risk.
- **Next 60 days** — Stand up the Semgrep + CodeQL custom rule packs and the ModelScan CI integration. Publish the paved-road template v0. Begin Llama Guard shadow-mode measurement.
- **Next 90 days** — Operate the prompt linter v0. Have the asset-level Security Report Card running for at least three Tier 1 candidate apps. Be ready to present cycle-time data as part of the Phase 2 ask.

Threat Intelligence lead

- **Next 30 days** — Confirm the AI threat-feed taxonomy scope and the BAA inventory data sources. Identify one pilot CASB integration to use as the shadow-AI discovery first stop.
- **Next 60 days** — BAA inventory baseline complete. Jailbreak intel weekly report running for two cycles. Shadow-AI discovery v0 producing a weekly inventory of unregistered AI usage.
- **Next 90 days** — Healthcare-AI TTP catalog v0 published. Provider-incident watch operational. First intel-driven replay pattern documented (even if not yet automated).

Threat Hunt lead

- **Next 30 days** — Deliver the telemetry gap analysis. This is the single most important Phase 1 input from your team — it sets the spec for what Platform Engineering builds.
- **Next 60 days** — First three hunt hypotheses operational against the available telemetry. Hunt notebook templates published.
- **Next 90 days** — First hunt finding produced from production AI telemetry. Even one credible hunt result in Phase 1 reframes the Phase 2 conversation about telemetry investment.

Red Team lead

- **Next 30 days** — Select the demo red-team target. This is the most important strategic call any single lead makes in Phase 1. The right target is a real Tier 1 app with a recognizable business sponsor and visible AI features — not a sandbox.
- **Next 60 days** — garak and PyRIT PoC operational. Healthcare custom converters drafted. Demo red-team exercise complete and written up as a polished artifact.
- **Next 90 days** — MCP onboarding red-team v0 used on the first three registry submissions. Phase 2 ask packaged around the demo red-team write-up.

Security Control Validation lead

- **Next 30 days** — Deliver the v2.1 controls × AI threat model gap matrix. This is the work backlog for the rest of the team for Phases 2 and 3.
- **Next 60 days** — Egress-control validation playbook running. Gateway-bypass detection in production at least in alert-only mode.
- **Next 90 days** — Be able to answer, with evidence, the question: 'Which v2.1 controls are validated, which are partially validated, and which are unvalidated?' That answer goes into the first quarterly board report.

What we collectively owe each other

- Honest assessments. If a Phase 1 deliverable is at risk, that is a conversation now, not a slip later.
- Cross-vertical handoffs. Most pipeline stages have multiple supporters. Supporting work is not optional and not invisible.
- Shared dashboard discipline. Every panel is owned by a lead who can defend the number; no cherry-picking.
- The board report. Every quarter, on time, with a defensible posture statement. This is the seat-at-the-table claim — earn it by repetition.